

purdue-l35-it-ot-boundary brief

Purdue IT/OT Boundary (Level 3.5 — Industrial DMZ) — Cross-Vendor Threat & Detection Brief

Scope: Purdue Level 3.5 is the crossover zone between IT management (L4/L3) and OT operations (L2 and below). The roles that live here are industrial firewalls, NMCs (network management cards) bridging IT-side monitoring with OT-side power infrastructure, industrial Ethernet switches, console-server / serial aggregators, and jump hosts. This layer is the **first one external attackers reach** — CISA's 2022 internet-exposed-UPS advisory was explicitly about this layer. Source material aggregated from [apc brief](#) (NMC2/NMC3/AP86xx — dominant), [eaton brief](#) (Network-M2/M3, Industrial-Gateway, USHA, legacy NMC — dominant), [vertiv brief](#) (Avocent ACS 8000 console server, IS-UNITY-DP), [siemens brief](#) (SCALANCE switches + S615 firewall, RUGGEDCOM), [rockwell brief](#) (Stratix industrial switches), and [schneider brief](#) (ConneXium — minimal coverage in source). NMC firmware extraction is broad and direct for APC/Eaton/Vertiv; switch/firewall firmware (SCALANCE, RUGGEDCOM, Stratix, ConneXium) is research-only in source briefs.

Architecture grouping (organized by ROLE within this layer, not by vendor)

Class (role)	Products (cross-vendor)	Stack	Catalog depth
A. Power-infra NMC (modern signed)	APC NMC3 AP9640/9641/9643; Eaton Network-M3 v2.3.3, Industrial-Gateway-Card / -X2 / -M3, Rack PDU G4 v4.0.1, PXGMS, Power-Xpert-Gateway; Vertiv Liebert IS-UNITY-DP	Signed firmware boot (APC ECDSA "Trusted Platform"), ARM Linux + Yocto (Eaton) or ext2 rootfs (Vertiv), HTTPS/SSHv2/SNMPv3, Modbus TCP, BACnet/IP	see apc brief Group A (83 hashes), eaton brief Group A (3,800–5,800 hashes), vertiv brief Group B (8,437 hashes)
B. Power-infra NMC (legacy / TLStorm lineage)	APC NMC2 AP9630/9631/9635; Eaton Network-MS (ee-he/hf/jc/jl/kb/lc/ld/le), Industrial-Modbus-Card, X-Slot-Modbus	Mocana NanoSSL (APC), proprietary <code>NmcKA</code> / <code>inmc</code> (Eaton); Telnet+FTP often default-on; SNMPv1/v2c	see apc brief Group B (86 hashes), eaton brief Group C (2–7 hashes per variant, opaque)
C. Power-infra NMC (ESP32 / flat-HTML class)	Eaton BestLink, ConnectUPS, ConnectUPS-Web-SNMP-Card	ESP32 + flat HTML web UI, no real OS, monolithic firmware	see eaton brief Group B (88–184 hashes, carved)
D. Switched/metered Rack PDU NMC	APC Rack PDU 2G AP86xx (AP8941, AP8959, AP8861, AP8865); Vertiv Geist GU/GUL/I03/R-series Upgradeable	NMC variant retargeted for outlet control; HTTPS/SSH/SNMPv3 + per-outlet <code>rPDU2OutletSwitchedControlCommand</code>	see apc brief Group C (72 hashes), vertiv

Class (role)	Products (cross-vendor)	Stack	Catalog depth
			brief Group D (research only)
E. Console server / serial aggregator	Vertiv Avocent ACS 8000 (4/8/16/32/48-port)	ARM Linux + busybox + OpenSSH + lighttpd + <code>portslave</code> / <code>cycladesd</code> serial daemons	see vertiv brief Group A (34,689 hashes)
F. Industrial firewall / industrial switch	Siemens SCALANCE XB-200, XC-200, XM-400, XR-500, S615 (firewall), W-700 (wireless); Siemens RUGGEDCOM RSG2100, RST2228, RX1500; Rockwell Stratix 5700/5400/5410/5800/8000/8300 (Cisco IE OEM); Schneider ConneXium	Linux on MIPS/ARM (SCALANCE); ROS proprietary or ROX II Linux (RUGGEDCOM); Cisco IOS/IOS-XE (Stratix)	see siemens brief Groups E/F (research only), rockwell brief Group G (research only)
G. Telecom DC-plant controllers	Vertiv NetSure 211/501/701/801 (M830B / NCU+ / ACU+)	ARM Linux + proprietary "ACU" web UI; SSH/HTTPS/SNMP/Modbus over -48VDC plant	see vertiv brief Group E (research only)

Group A — Power-infra NMC (modern signed)

Direct attack surface: HTTPS (TLS 1.2/1.3), SSHv2, SNMPv3 (v1/v2c often disabled by default in current builds), Modbus TCP/502 (opt-in), BACnet/IP UDP/47808, RADIUS client, syslog client. Signed-image boot rejects downgrade to unsigned predecessors on APC NMC3 and Eaton's modern Yocto stack. SNMPv1/v2c and Telnet binaries are typically present-but-disabled.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2022-22805	9.0	APC	NMC3 (TLS reassembly, "TLStorm" #1)	Pre-auth memory-corruption RCE via crafted TLS packets
CVE-2022-22806	9.0	APC	NMC3 (TLS state-confusion, "TLStorm" #2)	Auth bypass during TLS handshake
CVE-2026-22613	—	Eaton	Network-M3 firmware-upgrade	Insecure server identity check → on-path MITM swaps firmware payload
CVE-2025-22495	8.4	Eaton	Network-M2 (NTP-server config)	Authenticated command injection → RCE (fixed in 3.0.4)
ETN-VA-2025-1009	—	Eaton	ePDU G3	Web/SNMP class (verify advisory detail)
Bishop Fox advisory	—	Eaton	9PX 8000 SP	Password disclosed in web UI HTML source + CSRF on change-password
CISA ICSA-22-167-15	—	Vertiv	Liebert IS-UNITY	Use of hard-coded credentials + insufficiently protected credentials

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) — TLStorm proved the TLS *parser* is the pre-auth attack surface even on signed-firmware NMCs; firmware signing protects the flash path, not the live network parser.

Group B — Power-infra NMC (legacy / TLStorm lineage)

Direct attack surface: HTTPS on older OpenSSL / Mocana NanoSSL; SSHv1/v2; Telnet default-on pre-6.0.6 (APC); FTP default-on pre-6.x as firmware-upload channel (APC); SNMPv1/v2c with `public / private` (APC) or `public / private / Eaton` (Eaton) baseline communities; Modbus TCP/502; BACnet/IP UDP/47808; web UI superuser `apc / apc` baked into factory state (APC). Legacy Eaton NmckA/inmc cards are opaque proprietary containers with no firmware signing, telnet+HTTP only, Modbus TCP no-auth — **cannot be patched, only isolated**.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2022-22805	9.0	APC	NMC2 (Mocana NanoSSL packet-reassembly)	Pre-auth RCE via crafted TLS — Armis TLStorm ; fixed in NMC2 ≥ 6.9.6
CVE-2022-22806	9.0	APC	NMC2 TLS state-confusion	Auth bypass — TLStorm #2

CVE	CVSS	Vendor	Product	Vector
CVE-2022-0715	8.9	APC	NMC2/NMC3 firmware-upgrade	Unsigned firmware accepted → persistence (TLStorm #3)
CISA ICSA-22-083-01	—	APC	Smart-UPS family	Authoritative TLStorm advisory bundle
(no public CVEs in last 4 years)	—	Eaton	Network-MS NmckA family	EOL + no scrutiny ≠ no bugs — assume any input-handling code unaudited

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) chained into [T0857 System Firmware](#) — TLStorm RCE → CVE-2022-0715 persistence as legitimate firmware.

Group C — Power-infra NMC (ESP32 / flat-HTML class)

Direct attack surface: Carved HTML files reveal `Menu.html`, `PSnmp.html`, `PTrap.html`, `PMail.html`, `PPasswd.html`, `PWDate.html`, `PIdent.html` — web UI manages SNMP communities, trap targets, SMTP for alerts, passwords, time sync, identity. SNMP v1/v2c with default community strings (`public` / `private` / `Eaton`). TFTP / unauthenticated firmware upload via `BestLink upgrade utility.exe` - style flow. Telnet often present on older revisions. Cleartext credentials in HTTP responses (9PX 8000 SP "password in page source" pattern likely also present here).

Top attack vector (MITRE ATT&CK ICS): [T0857 System Firmware](#) — ESP32 firmware is monolithic and the BestLink-style upgrade utility flashes without verifying signatures.

Group D — Switched/metered Rack PDU NMC

Direct attack surface: HTTPS/SSH/SNMPv3 web UI; per-outlet ON/OFF/CYCLE control endpoints; SNMP `epdu` MIB (`rPDU2OutletSwitchedControlCommand`, `rPDU2OutletSwitchedConfigPowerOnDelay`). Geist defaults `admin` / `admin` historically; APC AP86xx ships historically with SNMPv1 `private` write community enabled.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2022-22805	9.0	APC	Rack PDU 2G AP86xx (same Mocana stack as NMC2)	TLStorm parser RCE on pre-2022 fix line

CVE	CVSS	Vendor	Product	Vector
CVE-2022-0715	8.9	APC	AP86xx	Unsigned-firmware acceptance
CISA ICSA-22-242-15	—	Vertiv	Geist Rack PDU	Multiple — weak session mgmt, XSS, info disclosure
Vertiv PSIRT	—	Vertiv	Geist Upgradeable PDU	Authenticated path traversal / file read

Top attack vector (MITRE ATT&CK ICS): [T0879 Damage to Property](#) via [T0855 Unauthorized Command Message](#) — a single SNMP `Set` to `rPDU20outletSwitchedControlCommand` with `value=2` powers off a rack. Mass-PDU coordinated outlet shutdown was explicitly modeled by CISA in the 2022 internet-exposed-UPS advisory.

Group E — Console server / serial aggregator

Direct attack surface: `sshd`, `lighttpd` (HTTPS web UI), `portslave` / `cycladesd` (serial multiplexer), `snmpd` (v1/v2c/v3), `ipsec` (strongSwan), `dhcpcd`, `rsyslogd`, `radclient` (RADIUS/TACACS). Default config ships with `root` / `admin` accounts and password-auth SSH until first boot. The ACS 8000 brokers serial consoles for everything in the rack — routers, PDUs, BMCs, IPMI — so a compromised ACS is a console-level pivot into every device cabled to it, **bypassing each device's own network ACLs**.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CISA ICSA-23-285-06	—	Vertiv	Avocent ACS 8000 firmware ≤ 3.3.x	OS command injection + auth bypass + hardcoded root creds
Vertiv PSIRT	—	Vertiv	Avocent ACS 8000	Hardcoded credential / insecure default — <code>rootfs</code> <code>/etc/shadow</code> audit required
Nozomi Networks Labs	—	Vertiv	ACS 8000	Chained unauth → root via web UI + serial daemon

Top attack vector (MITRE ATT&CK ICS): [T0859 Valid Accounts](#) into the console server, then [T0822 External Remote Services](#) — every serial port becomes a remote-access vector into the connected device.

Group F — Industrial firewall / industrial switch

Direct attack surface: SSH, SNMP v1/v2c/v3, HTTP/HTTPS web management, RADIUS, syslog. SCALANCE S615 adds firewall/VPN termination; SCALANCE W-700 adds 802.11 wireless management. RUGGEDCOM ROX II runs Linux; ROS is proprietary. Stratix inherits the entire Cisco IOS / IOS-XE CVE surface.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
Siemens ProductCERT — SCALANCE X-200 web-UI advisory class	8.8	Siemens	SCALANCE X-200	Authenticated web UI command injection
Siemens ProductCERT — SCALANCE/RUGGEDCOM SSH-web advisory class	7.x	Siemens	SCALANCE / RUGGEDCOM	Multiple auth & command-injection issues
Siemens ProductCERT — SCALANCE W-700 SNMP advisory class	7.5	Siemens	SCALANCE W-700	SNMP DoS
CVE-2024-3596 — BlastRADIUS	9.0	Siemens	SCALANCE/SIMATIC with RADIUS	MITM auth bypass against RADIUS-enabled deployments
CISA — RUGGEDCOM ROS advisories	n/a	Siemens	RUGGEDCOM ROS	Multiple substation-class advisories
Cisco IOS/IOS-XE CVE stream	varies	Rockwell	Stratix 5700/5400/5410/5800/8000/8300	Inherited Cisco IE platform vulns (track Cisco PSIRT, not Rockwell)

Top attack vector (MITRE ATT&CK ICS): [T0830 Adversary-in-the-Middle](#) — switch/firewall compromise enables CIP / Modbus / S7comm packet manipulation against every controller behind it, plus the Symbiote-class mirror-to-C2 pattern.

Group G — Telecom DC-plant controllers

Direct attack surface: SSH, HTTP/HTTPS, SNMP v1/v2c/v3, Modbus TCP, YDN23 (China telecom protocol). NetSure controllers (M830B / NCU+ / ACU+) sit on -48VDC central-office plants — loss-

of-view or rectifier shutdown is a direct telecom outage primitive. [CISA ICSA-22-242-15](#) covered the M830B for hard-coded credentials and improper auth.

Top attack vector (MITRE ATT&CK ICS): [T0822 External Remote Services](#) — NetSure is often the only thing keeping the central-office DC plant up.

Logging matrix (highest priority for this layer)

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	NMC syslog (UDP/514) — APC + Eaton + Vertiv	Firmware updated outside change-window OR firmware version downgrade	TLStorm-class persistence (CVE-2022-0715), tampered firmware push	T0857 System Firmware
2	Network IDS (Suricata/Zeek)	TLS handshake to NMC IP with abnormal record length / fragmented ClientHello	TLStorm CVE-2022-22805/22806 exploit traffic	T0866 Exploitation of Remote Services
3	Network IDS	SNMP Set-Request to rPDU2OutletSwitchedControlCommand from non-mgmt-VLAN source	Single-packet rack power-off on AP86xx / Geist	T0855 Unauthorized Command Message
4	ACS 8000 syslog	login.success for root from any IP plus any subsequent portmgr activity	Confirmed compromise of console aggregator → cabled-device pivot	T0859 Valid Accounts
5	NMC syslog	Configuration changed + User created + SNMP community modified within 5 min	Persistence + parameter modification	T0836 Modify Parameter
6	Firewall NetFlow	Any egress from UPS/PDU/NMC/console-server VLAN to non-RFC1918	The CISA 2022 internet-exposure warning — NMCs should never originate outbound	n/a (perimeter)
7	SCALANCE / RUGGEDCOM / Stratix syslog	Port-link bounce on OT port, MAC move on controller IP, unexpected RADIUS auth	AitM insertion, rogue device, BlastRADIUS exploitation	T0830 Adversary-in-the-Middle

#	Source	Event	What it catches	MITRE ATT&CK ICS
8	NMC syslog	Authentication failed x N followed by User logged in within 60s	Brute-force success on apc / apc , admin / admin , OR rotated creds	T0812 Default Credentials

Secondary: SNMP trap collector (subscribe to upsBasicTrapsOnBattery , rPDU2OutletSwitchedStatusState , lgpEnvTemperatureThresholdAlarm); NMC native audit logs (APC Logs → Config → Audit Log syslog'd, Eaton M2/M3 Settings → Management → System logs , Vertiv ACS 8000 System → Logging → Data Buffering + Auditing); NMC3 Trusted Platform boot-failure events.

Cross-layer pivots

- L4 corporate IT → L3.5 via internet-exposed NMC.** The CISA 2022 UPS advisory called this out directly: APC/Eaton/Vertiv NMCs deployed on routable corporate IP with factory creds (apc / apc , admin / admin , SNMPv1 public / private) are the most common first foothold from the public internet into industrial infrastructure. **L3.5 is the first layer external attackers reach.**
- L3.5 NMC → L0 power infrastructure** (single-packet destructive write). SNMP Set to rPDU2OutletSwitchedControlCommand value=2 on an AP86xx or Geist PDU = rack power-off. SNMP Set or Velocity write to a Liebert IS-UNITY-DP = cooling disabled / UPS forced battery-test. No CIP/S7comm/UMAS required — this pivot reaches L0 with one UDP packet.
- L3.5 industrial switch backdoor → mirror/tap OT traffic to attacker C2** (Symbiote-class). SCALANCE / RUGGEDCOM / Stratix compromise via vendor web-UI command-injection or BlastRADIUS (CVE-2024-3596) enables span-port redirection and CIP/Modbus packet manipulation against every controller behind the switch.
- L3.5 jump host / console aggregator → L3 SCADA or L2 controllers via shared AD trust or serial cabling.** Avocent ACS 8000 (CISA ICSA-23-285-06) holds serial-console access to every device cabled to it — routers, PDUs, BMCs, IPMI, PLC consoles. Compromising the ACS bypasses every downstream device's network ACLs and lands directly on its console at SYSTEM/root.

Power Infrastructure appendix (cross-cuts L0/L1)

This appendix aggregates power-specific surfaces that do not fit cleanly inside a single Purdue level because their networked control plane lives at L3.5 while the physical effect is at L0/L1.

Eaton Group D — Bare-metal UPS MCU (.sta family): 5P / 5PX / 5SC / 9PX / 9SX / 9PXM / 9170+ / Blade / Ferrups; STM32 / Callisto chipset; .sta flat memory blocks; 6–96 hashes; **no network attack surface on the UPS itself — reaches the network only via a connected NMC.** Cross-layer note: the L3.5 NMC compromise is what makes this L0 device tampering reachable. Vendor SHA256s in `manifest.json` can catch tampered blocks during flash. Battery-management parameter abuse on Li-Ion products (9PX Lithium-Ion, 5P 1U-Lithium-Ion) carries thermal-runaway risk. See [eaton brief Group D](#).

Eaton Group E — PDU G3 (STM32 + Shark web UI): STM32 with embedded SNMP MIBs + zipped Shark web UI; 14 hashes; advisory ETN-VA-2025-1009 covers a web/SNMP class on this family. See [eaton brief Group E](#).

APC Smart-UPS internal MCUs: Internal UPS controllers reached via the NMC2/NMC3 management card — TLStorm CVE-2022-0715 (unsigned-firmware acceptance) was originally demonstrated against the Smart-UPS line. The internal MCU has no independent network surface; the L3.5 NMC is the only path. See [apc brief Group B](#) and [CISA ICSA-22-083-01](#).

Vertiv Liebert GXT5 Lithium-Ion UPS controller: Renesas/STM32 MCU; 5 hashes; monolithic firmware blob; no network attack surface on the UPS itself — reaches the network only via the attached IS-UNITY NMC. **Vertiv does not publish per-block SHA256 manifests the way Eaton does** — flashes are not externally verifiable. Tampered GXT5 firmware that disables cell-temperature shutoff is a credible thermal-runaway path on Li-Ion. See [vertiv brief Group C](#).

Sources

- [CISA — Mitigating Attacks Against UPS Devices \(2022\)](#)
- [CISA ICSA-22-083-01 — APC Smart-UPS \(TLStorm\)](#)
- [CISA ICSA-23-285-06 — Vertiv Avocent ACS 8000](#)
- [CISA ICSA-22-167-15 — Vertiv Liebert IS-UNITY](#)
- [CISA ICSA-22-242-15 — Vertiv Geist Rack PDU / NetSure](#)
- [CISA ICS Advisories — RUGGEDCOM index](#)
- [Armis — TLStorm research \(3 zero-days in APC Smart-UPS\)](#)
- [Schneider PSIRT — Security Notifications index](#)
- [Eaton PSIRT advisory index](#)
- [Vertiv PSIRT / security advisory index](#)
- [Siemens ProductCERT advisory index](#)
- [Rockwell Automation Trust Center — Security Advisories](#)
- [Bishop Fox — Eaton 9PX 8000 SP multiple vulnerabilities](#)

- [Nozomi Networks Labs — Avocent ACS 8000 research](#)
- [Claroty Team82 research blog \(Velocity / OT protocol research\)](#)
- [Forescout 2025 OT Threat Report — power-infrastructure & BACnet trends](#)
- [Dragos — ICS Cybersecurity Year in Review](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)
- [IEC 62443 — Industrial communication networks / security for IACS](#)
- [Purdue Enterprise Reference Architecture \(PERA\) — ISA-95 / IEC 62264](#)
- [MITRE ATT&CK for ICS — T0866 Exploitation of Remote Services](#)
- [MITRE ATT&CK for ICS — T0857 System Firmware](#)
- [MITRE ATT&CK for ICS — T0855 Unauthorized Command Message](#)
- [MITRE ATT&CK for ICS — T0879 Damage to Property](#)
- [MITRE ATT&CK for ICS — T0822 External Remote Services](#)
- [MITRE ATT&CK for ICS — T0830 Adversary-in-the-Middle](#)
- [MITRE ATT&CK for ICS — T0859 Valid Accounts](#)
- [MITRE ATT&CK for ICS — T0812 Default Credentials](#)
- [MITRE ATT&CK for ICS — T0836 Modify Parameter](#)
- [Per-vendor source briefs: \[apc brief\]\(#\), \[eaton brief\]\(#\), \[vertiv brief\]\(#\), \[siemens brief\]\(#\), \[rockwell brief\]\(#\), \[schneider brief\]\(#\)](#)